VULNERABILITY ASSESSMENT & PENETRATION TEST REPORT

# Assessment A-9a4f8d52

Generated by ARGUS (AI-assisted, evidence-grounded) · assessment A-9a4f8d52

| | |
|---|---|
| Authorized scope | 10.77.0.0/24 |
| Exclusions | 10.77.0.1, 10.77.0.2, 10.77.0.3 |
| Authorized by | Team ARGUS (own isolated lab) |
| Assessment window | 2026-11-06T15:19:56+00:00 to 2026-11-06T15:27:44+00:00 (UTC) |
| Report status | review; audit chain verified intact |

**Important.** This report was produced by an automated assistant from real tool output. Findings marked *suspected* or *observed* have not been manually verified. Use of the standards named here (NIST SP 800-115, OWASP Top 10, CVE, CVSS, CWE, MITRE ATT&CK, NIST CSF 2.0) is indicative and does not establish formal compliance.

# 1. Executive Summary

ARGUS assessed 1 authorized target(s) (10.77.0.0/24) and identified **36** distinct finding(s) across 2 host(s), plus 21 informational observation(s) (Appendix E). 2 additional tool alert(s) were investigated and **refuted as false positives**; they are listed in Appendix B and excluded from the risk ranking. 9 finding(s) were independently validated, and 6 were reported independently by more than one tool.

**Highest-priority issues** (ranked by a transparent score, see section 3): **F-058** Cross-site scripting (reflected) on 10.77.0.10:80 (priority 7.3, observed) [EV-0021]; **F-040** SQL Injection on 10.77.0.10:80 (priority 6.8, observed) [EV-0005] [EV-0018]; **F-041** SQL Injection on 10.77.0.10:80 (priority 6.8, observed) [EV-0005] [EV-0018].

**Overall assessment.** Significant weaknesses were found that warrant prompt remediation.

**Scope and rules of engagement.** All testing was restricted to the authorized lab scope above. Active or intrusive actions required recorded human approval (section 6).

# 2. Assessment Methodology

The assessment followed the planning, discovery, attack (validation) and reporting phases of NIST SP 800-115. The agent selected each next action from its current evidence (Decision Cards, Appendix C) rather than a fixed script. Every action passed a deterministic scope check and was written to a hash-chained audit log.

## Assets tested

10.77.0.10:- (n/a), 10.77.0.10:80 (http), 10.77.0.10:80 (www), 10.77.0.11:3000 (http)

## Tool execution summary

| Job | Tool | Mode | Target | Status | Started | Detail |
|---|---|---|---|---|---|---|
| J-001 | nmap | LIVE | 10.77.0.0/24 | OK | 15:19:59 | |
| J-002 | nmap | LIVE | 10.77.0.10 | OK | 15:20:15 | |
| J-003 | nmap | LIVE | 10.77.0.11 | OK | 15:20:23 | |
| J-004 | nikto | LIVE | http://10.77.0.10 | OK | 15:20:36 | |
| J-007 | zap | LIVE | http://10.77.0.10 | OK | 15:20:40 | |
| J-008 | nikto | LIVE | http://10.77.0.11:3000 | OK | 15:20:48 | |
| J-011 | zap | LIVE | http://10.77.0.11:3000 | OK | 15:22:30 | |
| J-012 | argus-http | LIVE | http://10.77.0.10:80/ | OK | 15:23:05 | |
| J-013 | argus-http | LIVE | http://10.77.0.10:80/ | OK | 15:23:07 | |
| J-014 | argus-http | LIVE | http://10.77.0.10/sitemap.xml | OK | 15:23:07 | |
| J-015 | argus-http | LIVE | http://10.77.0.10:80/ | OK | 15:23:08 | |
| J-016 | argus-http | LIVE | http://10.77.0.10 | OK | 15:23:09 | |
| J-017 | argus-http | LIVE | http://10.77.0.10/login.php | OK | 15:23:09 | |
| J-018 | argus-http | LIVE | http://10.77.0.10 | OK | 15:23:10 | |
| J-019 | argus-http | LIVE | http://10.77.0.10:80/config/ | OK | 15:23:11 | |
| J-020 | argus-http | LIVE | http://10.77.0.11:3000/ | OK | 15:23:11 | |
| J-021 | argus-http | LIVE | http://10.77.0.11:3000/ | OK | 15:23:12 | |
| J-022 | zap | LIVE | http://10.77.0.10 | OK | 15:23:23 | |
| J-023 | metasploit | LIVE | 10.77.0.10 | OK | 15:24:12 | |
| J-024 | argus-http | LIVE | http://10.77.0.10:80/ | OK | 15:26:35 | |
| - | nessus | IMPORT | imported file SAMPLE-sample_nessus | OK | 15:26:10 | file imported, not executed |

| Job | Tool | Mode | Target | Status | Started | Detail |
|---|---|---|---|---|---|---|
| - | burp | IMPORT | imported file SAMPLE-sample_burp_d | OK | 15:26:14 | file imported, not executed |
| - | openvas | IMPORT | imported file SAMPLE-sample_openva | OK | 15:26:17 | file imported, not executed |
| - | nessus | IMPORT | imported file oos.nessus | OK | 15:26:23 | file imported, not executed |
| - | nessus | IMPORT | imported file bad.nessus | OK | 15:26:28 | file imported, not executed |

## Integration status (truthful)

| Tool | Status | Runtime now | Limitations |
|---|---|---|---|
| nmap | LIVE | ready | Requires the argus-tools container. No vulners script: CVE hints come only from a small reference table. |
| nessus | IMPORT-ONLY | ready | Commercial product; live API integration is not implemented or claimed. Informational plugins are treated as context. |
| openvas | IMPORT-ONLY | ready | Live GMP integration is Planned (Greenbone community feed sync is heavy); import is supported. |
| nikto | LIVE | ready | Nikto reports no CVSS and no severity; ARGUS derives a coarse severity from the message and marks it as derived. |
| zap | LIVE | ready | Needs the argus-zap daemon. ZAP does not provide CVSS scores; none are fabricated. |
| burp | IMPORT-ONLY | ready | Burp Community has no scanner export/API; Burp Pro REST API integration is Planned, not implemented. |
| metasploit | LIVE | ready | Requires the metasploit-framework Docker image (large) and an approved action. Exploit modules are NOT supported by design. Not autonomous. |

# 3. Severity Distribution and Prioritized Findings

| Severity (as reported) | Count |
|---|---|
| CRITICAL | 0 |
| HIGH | 3 |
| MEDIUM | 17 |
| LOW | 16 |
| INFO | 0 |

**How priority is computed:** priority = min(10, base × exposure × exploitability × asset criticality × confidence weight). Base is the CVSS score reported by a tool; when no tool supplies CVSS, the midpoint of the tool-reported severity is used and labelled as such. No CVSS value in this report was generated by ARGUS. The KEV check uses a small, partial offline snapshot.

| Rank | ID | Finding | Asset | Sev. | Priority | Status | Conf. |
|---|---|---|---|---|---|---|---|
| 1 | F-058 | Cross-site scripting (reflected) | 10.77.0.10:80 | HIGH | 7.3 | observed | 50 (medium) |
| 2 | F-040 | SQL Injection | 10.77.0.10:80 | HIGH | 6.8 | observed | 40 (medium) |
| 3 | F-041 | SQL Injection | 10.77.0.10:80 | HIGH | 6.8 | observed | 40 (medium) |
| 4 | F-004 | Suggested security header missing: content-security-policy. | 10.77.0.10:80 | MEDIUM | 6.0 | validated | 90 (high) |
| 5 | F-007 | Directory indexing found. | 10.77.0.10:80 | MEDIUM | 5.5 | validated | 90 (high) |
| 6 | F-047 | Suggested security header missing: content-security-policy. | 10.77.0.11:3000 | MEDIUM | 5.5 | validated | 90 (high) |
| 7 | F-039 | Absence of Anti-CSRF Tokens | 10.77.0.10:80 | MEDIUM | 5.2 | observed | 55 (medium) |
| 8 | F-017 | Missing Anti-clickjacking Header | 10.77.0.10:80 | MEDIUM | 4.8 | validated | 90 (high) |
| 9 | F-020 | Application Error Disclosure | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 10 | F-024 | Absence of Anti-CSRF Tokens | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 11 | F-025 | Absence of Anti-CSRF Tokens | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 12 | F-027 | Absence of Anti-CSRF Tokens | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 13 | F-028 | Sub Resource Integrity Attribute Missing | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 14 | F-029 | Absence of Anti-CSRF Tokens | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |

| Rank | ID | Finding | Asset | Sev. | Priority | Status | Conf. |
|---|---|---|---|---|---|---|---|
| 15 | F-030 | Absence of Anti-CSRF Tokens | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 16 | F-034 | Absence of Anti-CSRF Tokens | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 17 | F-036 | CSP: Failure to Define Directive with No Fallback | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 18 | F-037 | CSP: Wildcard Directive | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 19 | F-038 | CSP: style-src unsafe-inline | 10.77.0.10:80 | MEDIUM | 4.7 | observed | 55 (medium) |
| 20 | F-055 | Cross-Domain Misconfiguration | 10.77.0.11:3000 | MEDIUM | 4.7 | observed | 55 (medium) |
| 21 | F-016 | Cookie No HttpOnly Flag | 10.77.0.10:80 | LOW | 3.0 | validated | 90 (high) |
| 22 | F-057 | Web Server Transmits Cleartext Credentials | 10.77.0.10:80 | LOW | 2.6 | observed | 35 (low) |
| 23 | F-001 | Apache/2.4.25 appears to be outdated (current is at least 2.4.68). | 10.77.0.10:80 | LOW | 2.5 | validated | 90 (high) |
| 24 | F-005 | Suggested security header missing: x-content-type-options. | 10.77.0.10:80 | LOW | 2.5 | validated | 90 (high) |
| 25 | F-014 | Server Leaks Version Information via "Server" HTTP Response Header Fie | 10.77.0.10:80 | LOW | 2.5 | validated | 90 (high) |
| 26 | F-018 | Cookie without SameSite Attribute | 10.77.0.10:80 | LOW | 2.5 | validated | 90 (high) |
| 27 | F-059 | TCP Timestamps Information Disclosure | 10.77.0.10:- | LOW | 2.2 | observed | 35 (low) |
| 28 | F-002 | Suggested security header missing: permissions-policy. | 10.77.0.10:80 | LOW | 2.1 | observed | 40 (medium) |
| 29 | F-003 | Suggested security header missing: referrer-policy. | 10.77.0.10:80 | LOW | 2.1 | observed | 40 (medium) |
| 30 | F-013 | In Page Banner Information Leak | 10.77.0.10:80 | LOW | 2.1 | observed | 55 (medium) |
| 31 | F-023 | Information Disclosure - Debug Error Messages | 10.77.0.10:80 | LOW | 2.1 | observed | 55 (medium) |
| 32 | F-026 | Cross-Domain JavaScript Source File Inclusion | 10.77.0.10:80 | LOW | 2.1 | observed | 55 (medium) |
| 33 | F-032 | Private IP Disclosure | 10.77.0.10:80 | LOW | 2.1 | observed | 55 (medium) |

| Rank | ID | Finding | Asset | Sev. | Priority | Status | Conf. |
|---|---|---|---|---|---|---|---|
| 34 | F-035 | Timestamp Disclosure - Unix | 10.77.0.10:80 | LOW | 2.1 | observed | 55 (medium) |
| 35 | F-046 | Suggested security header missing: referrer-policy. | 10.77.0.11:3000 | LOW | 2.1 | observed | 40 (medium) |
| 36 | F-049 | Suggested security header missing: permissions-policy. | 10.77.0.11:3000 | LOW | 2.1 | observed | 40 (medium) |

# 4. Detailed Vulnerability Findings

## F-058 — Cross-site scripting (reflected)

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/xss_r/<br>Parameter: name parameter |
| Severity / CVSS | **HIGH** (reported by burp) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-79 / A03:2021 Injection |
| MITRE ATT&CK (indicative) | T1059.007 |
| Validation status | **OBSERVED** · confidence 50/100 (medium) |
| Priority | 7.3 (rank 1) |

**OBSERVED (tool evidence):** Reflected cross-site scripting vulnerabilities arise when data is copied from a request and echoed into the application's immediate response in an unsafe way.
Reported by: burp (IMPORT) [EV-0021] rule burp:2097920

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | -5 only from an imported file (not re-executed by ARGUS) | burp-confidence:Certain
Risk factors: base 8.0 (no CVSS available; midpoint of 'high' severity (burp)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-040 — SQL Injection

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/setup.php<br>Parameter: create_db |
| Severity / CVSS | **HIGH** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-89 / A03:2021 Injection |
| MITRE ATT&CK (indicative) | T1190 |
| Validation status | **OBSERVED** · confidence 40/100 (medium) |
| Priority | 6.8 (rank 2) |

**OBSERVED (tool evidence):** SQL injection may be possible.
Reported by: zap (LIVE) [EV-0005] rule zap:40018, zap (LIVE) [EV-0018] rule zap:40018

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | zap-confidence:Medium
Risk factors: base 8.0 (no CVSS available; midpoint of 'high' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-041 — SQL Injection

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/instructions.php?doc=readme%27+AND+%271%27%3D%271%27+--+<br>Parameter: doc |
| Severity / CVSS | **HIGH** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-89 / A03:2021 Injection |
| MITRE ATT&CK (indicative) | T1190 |
| Validation status | **OBSERVED** · confidence 40/100 (medium) |
| Priority | 6.8 (rank 3) |

**OBSERVED (tool evidence):** SQL injection may be possible.
Reported by: zap (LIVE) [EV-0005] rule zap:40018, zap (LIVE) [EV-0018] rule zap:40018

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | zap-confidence:Medium
Risk factors: base 8.0 (no CVSS available; midpoint of 'high' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-004 — Suggested security header missing: content-security-policy.

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10:80/, http://10.77.0.10/sitemap.xml, http://10.77.0.10/login.php, http://10.77.0.10/dvwa/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-693 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by argus-http-check - No Content-Security-Policy header in the response. [EV-0009] |
| Priority | 6.0 (rank 4) |

**OBSERVED (tool evidence):** Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Reported by: nikto (LIVE) [EV-0004] rule nikto:013587, zap (LIVE) [EV-0005] rule zap:10038, zap (LIVE) [EV-0018] rule zap:10038

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:High | retest: still present: No Content-Security-Policy header in the response.
Retest history: 2026-11-06T15:26:36 validated -> validated (confirmed) [EV-0025]
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-007 — Directory indexing found.

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10:80/config/, http://10.77.0.10:80/docs/, http://10.77.0.10/dvwa/, http://10.77.0.10/dvwa/css/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-548 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by argus-http-check - The response is an auto-generated directory index ('Index of /'). [EV-0015] |
| Priority | 5.5 (rank 5) |

**OBSERVED (tool evidence):** It is possible to view a listing of the directory contents. Directory listings may reveal hidden scripts, include files, backup source files, etc., which can be accessed to reveal sensitive information. Evidence: <title>Index of /dvwa/includes/DBMS</title>
Reported by: nikto (LIVE) [EV-0004] rule nikto:750500, zap (LIVE) [EV-0005] rule zap:10033, zap (LIVE) [EV-0018] rule zap:10033, nessus (IMPORT) [EV-0020] rule nessus:40984

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +35 independently reported by 3 tools (nessus, nikto, zap) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-047 — Suggested security header missing: content-security-policy.

| | |
|---|---|
| Affected asset | 10.77.0.11:3000<br>URLs: http://10.77.0.11:3000/, http://10.77.0.11:3000, http://10.77.0.11:3000/sitemap.xml, http://10.77.0.11:3000/ftp |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-693 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by argus-http-check - No Content-Security-Policy header in the response. [EV-0017] |
| Priority | 5.5 (rank 6) |

**OBSERVED (tool evidence):** Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Reported by: nikto (LIVE) [EV-0006] rule nikto:013587, zap (LIVE) [EV-0007] rule zap:10038

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:High | validation: confirmed by argus-http-check: No Content-Security-Policy header in the response.
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-039 — Absence of Anti-CSRF Tokens

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/csp/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-352 / A01:2021 Broken Access Control |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 5.2 (rank 7) |

**OBSERVED (tool evidence):** No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0005] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-017 — Missing Anti-clickjacking Header

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/login.php, http://10.77.0.10/dvwa/, http://10.77.0.10/dvwa/css/, http://10.77.0.10/dvwa/images/<br>Parameter: x-frame-options |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: 4.3 CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N (source: nessus) |
| CVE / CWE / OWASP | none reported / CWE-1021 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by argus-http-check - Neither X-Frame-Options nor a CSP frame-ancestors directive is present in the response. [EV-0013] |
| Priority | 4.8 (rank 8) |

**OBSERVED (tool evidence):** The remote web server does not set an X-Frame-Options response header or a Content-Security-Policy 'frame-ancestors' response header in all content responses. Plugin output: The following pages do not set a X-Frame-Options HTTP response header : http://10.77.0.10/
Reported by: zap (LIVE) [EV-0005] rule zap:10020, zap (LIVE) [EV-0018] rule zap:10020, nessus (IMPORT) [EV-0020] rule nessus:85582

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nessus, zap) | zap-confidence:Medium
Risk factors: base 4.3 (CVSS 4.3 reported by nessus); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-020 — Application Error Disclosure

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/dvwa/, http://10.77.0.10/dvwa/css/, http://10.77.0.10/dvwa/images/, http://10.77.0.10/dvwa/?C=N;O=D |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-550 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 9) |

**OBSERVED (tool evidence):** This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page. Evidence: HTTP/1.0 500 Internal Server Error
Reported by: zap (LIVE) [EV-0005] rule zap:90022, zap (LIVE) [EV-0018] rule zap:90022

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-024 — Absence of Anti-CSRF Tokens

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/exec/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-352 / A01:2021 Broken Access Control |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 10) |

**OBSERVED (tool evidence):** No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0005] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-025 — Absence of Anti-CSRF Tokens

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/upload/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-352 / A01:2021 Broken Access Control |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 11) |

**OBSERVED (tool evidence):** No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0005] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-027 — Absence of Anti-CSRF Tokens

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/captcha/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-352 / A01:2021 Broken Access Control |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 12) |

**OBSERVED (tool evidence):** No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0005] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-028 — Sub Resource Integrity Attribute Missing

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/captcha/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-345 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 13) |

**OBSERVED (tool evidence):** The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content. Evidence: <script src='https://www.google.com/recaptcha/api.js'></script>
Reported by: zap (LIVE) [EV-0005] rule zap:90003, zap (LIVE) [EV-0018] rule zap:90003

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-029 — Absence of Anti-CSRF Tokens

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/weak_id/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-352 / A01:2021 Broken Access Control |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 14) |

**OBSERVED (tool evidence):** No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0005] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-030 — Absence of Anti-CSRF Tokens

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/xss_s/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-352 / A01:2021 Broken Access Control |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 15) |

**OBSERVED (tool evidence):** No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0005] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-034 — Absence of Anti-CSRF Tokens

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/javascript/ |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-352 / A01:2021 Broken Access Control |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 16) |

**OBSERVED (tool evidence):** No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session ri
Reported by: zap (LIVE) [EV-0005] rule zap:10202, zap (LIVE) [EV-0018] rule zap:10202

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-036 — CSP: Failure to Define Directive with No Fallback

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/csp/<br>Parameter: Content-Security-Policy |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-693 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 17) |

**OBSERVED (tool evidence):** The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything. Evidence: script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl.google-analytics.com ;
Reported by: zap (LIVE) [EV-0005] rule zap:10055, zap (LIVE) [EV-0018] rule zap:10055

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-037 — CSP: Wildcard Directive

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/csp/<br>Parameter: Content-Security-Policy |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-693 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 18) |

**OBSERVED (tool evidence):** Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. Evidence: script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl
Reported by: zap (LIVE) [EV-0005] rule zap:10055, zap (LIVE) [EV-0018] rule zap:10055

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-038 — CSP: style-src unsafe-inline

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/csp/<br>Parameter: Content-Security-Policy |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-693 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 19) |

**OBSERVED (tool evidence):** Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. Evidence: script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl
Reported by: zap (LIVE) [EV-0005] rule zap:10055, zap (LIVE) [EV-0018] rule zap:10055

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-055 — Cross-Domain Misconfiguration

| | |
|---|---|
| Affected asset | 10.77.0.11:3000<br>URLs: http://10.77.0.11:3000/styles.css, http://10.77.0.11:3000/assets/public/favicon_js.ico, http://10.77.0.11:3000/rolldown-runtime-BoHGiXSq.js, http://10.77.0.11:3000/chunk-DBPdFzgj.js |
| Severity / CVSS | **MEDIUM** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-264 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 4.7 (rank 20) |

**OBSERVED (tool evidence):** Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server. Evidence: Access-Control-Allow-Origin: *
Reported by: zap (LIVE) [EV-0007] rule zap:10098

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 5.5 (no CVSS available; midpoint of 'medium' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-016 — Cookie No HttpOnly Flag

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10, http://10.77.0.10/, http://10.77.0.10/vulnerabilities/sqli/?id=1&Submit=Submit, http://10.77.0.10/login.php<br>Parameter: PHPSESSID |
| Severity / CVSS | **LOW** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-1004 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by argus-http-check - Cookie(s) PHPSESSID, PHPSESSID, security lack the httponly attribute. [EV-0012] |
| Priority | 3.0 (rank 21) |

**OBSERVED (tool evidence):** A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible. Evidence: Set-Cookie: PHPSESSID
Reported by: zap (LIVE) [EV-0005] rule zap:10010, zap (LIVE) [EV-0018] rule zap:10010, burp (IMPORT) [EV-0021] rule burp:5244416

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (burp, zap) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium | burp-confidence:Firm
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-057 — Web Server Transmits Cleartext Credentials

| | |
|---|---|
| Affected asset | 10.77.0.10:80 |
| Severity / CVSS | **LOW** (reported by nessus) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-523 / A02:2021 Cryptographic Failures |
| MITRE ATT&CK (indicative) | T1040 |
| Validation status | **OBSERVED** · confidence 35/100 (low) |
| Priority | 2.6 (rank 22) |

**OBSERVED (tool evidence):** The remote web server contains several forms that are susceptible to submit their data over HTTP cleartext instead of HTTPS. Plugin output: Page : /login.php Destination Page: /login.php
Reported by: nessus (IMPORT) [EV-0020] rule nessus:26194

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | -5 only from an imported file (not re-executed by ARGUS)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (nessus)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-001 — Apache/2.4.25 appears to be outdated (current is at least 2.4.68).

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10:80/ |
| Severity / CVSS | **LOW** (reported by derived from nikto message) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-1104 / A06:2021 Vulnerable and Outdated Components |
| MITRE ATT&CK (indicative) | T1190 |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by metasploit-aux - read-only module re-read version '2.4.25' from the live service [EV-0019] |
| Priority | 2.5 (rank 23) |

**OBSERVED (tool evidence):** Nikto test 600050 (HEAD /): Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
Reported by: nikto (LIVE) [EV-0004] rule nikto:600050

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | validation: confirmed by metasploit-aux: read-only module re-read version '2.4.25' from the live service
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-005 — Suggested security header missing: x-content-type-options.

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10:80/, http://10.77.0.10/robots.txt, http://10.77.0.10/dvwa/images/login_logo.png, http://10.77.0.10/dvwa/images/RandomStorm.png |
| Severity / CVSS | **LOW** (reported by derived from nikto message) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-693 / A05:2021 Security Misconfiguration |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by argus-http-check - X-Content-Type-Options header is absent. [EV-0011] |
| Priority | 2.5 (rank 24) |

**OBSERVED (tool evidence):** The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Reported by: nikto (LIVE) [EV-0004] rule nikto:013587, nikto (LIVE) [EV-0004] rule nikto:007352, zap (LIVE) [EV-0005] rule zap:10021, zap (LIVE) [EV-0018] rule zap:10021

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +25 independently reported by 2 tools (nikto, zap) | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-014 — Server Leaks Version Information via "Server" HTTP Response Header Field

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/sitemap.xml, http://10.77.0.10/robots.txt, http://10.77.0.10/dvwa/images/login_logo.png, http://10.77.0.10/dvwa/images/RandomStorm.png |
| Severity / CVSS | **LOW** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-497 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by argus-http-check - Response discloses software version: 'Apache/2.4.25 (Debian)'. [EV-0010] |
| Priority | 2.5 (rank 25) |

**OBSERVED (tool evidence):** The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to. Evidence: Apache/2.4.25 (Debian)
Reported by: zap (LIVE) [EV-0005] rule zap:10036, zap (LIVE) [EV-0018] rule zap:10036

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-018 — Cookie without SameSite Attribute

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10, http://10.77.0.10/, http://10.77.0.10/vulnerabilities/sqli/?id=1&Submit=Submit<br>Parameter: PHPSESSID |
| Severity / CVSS | **LOW** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-1275 / A01:2021 Broken Access Control |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **VALIDATED** · confidence 90/100 (high)<br>Validation: confirmed by argus-http-check - Cookie(s) PHPSESSID, PHPSESSID, security lack the samesite attribute. [EV-0014] |
| Priority | 2.5 (rank 26) |

**OBSERVED (tool evidence):** A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks. Evidence: Set-Cookie: PHPSESSID
Reported by: zap (LIVE) [EV-0005] rule zap:10054, zap (LIVE) [EV-0018] rule zap:10054

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x1.0

## F-059 — TCP Timestamps Information Disclosure

| | |
|---|---|
| Affected asset | 10.77.0.10:- |
| Severity / CVSS | **LOW** (reported by openvas) · CVSS: 2.6 (source: openvas) |
| CVE / CWE / OWASP | none reported / n/a / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 35/100 (low) |
| Priority | 2.2 (rank 27) |

**OBSERVED (tool evidence):** The remote host implements TCP timestamps and therefore allows to compute the uptime.
Reported by: openvas (IMPORT) [EV-0022] rule openvas:1.3.6.1.4.1.25623.1.0.80091

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | -5 only from an imported file (not re-executed by ARGUS)
Risk factors: base 2.6 (CVSS 2.6 reported by openvas); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-002 — Suggested security header missing: permissions-policy.

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10:80/ |
| Severity / CVSS | **LOW** (reported by derived from nikto message) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / n/a / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 40/100 (medium) |
| Priority | 2.1 (rank 28) |

**OBSERVED (tool evidence):** Nikto test 013587 (GET /): Suggested security header missing: permissions-policy.
Reported by: nikto (LIVE) [EV-0004] rule nikto:013587

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-003 — Suggested security header missing: referrer-policy.

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10:80/ |
| Severity / CVSS | **LOW** (reported by derived from nikto message) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / n/a / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 40/100 (medium) |
| Priority | 2.1 (rank 29) |

**OBSERVED (tool evidence):** Nikto test 013587 (GET /): Suggested security header missing: referrer-policy.
Reported by: nikto (LIVE) [EV-0004] rule nikto:013587

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-013 — In Page Banner Information Leak

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/sitemap.xml, http://10.77.0.10/var/www/html/config/config.inc.php, http://10.77.0.10/icons, http://10.77.0.10/DTD/xhtml1-transitional.dtd |
| Severity / CVSS | **LOW** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-497 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 2.1 (rank 30) |

**OBSERVED (tool evidence):** The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use. Evidence: Apache/2.4.25
Reported by: zap (LIVE) [EV-0005] rule zap:10009, zap (LIVE) [EV-0018] rule zap:10009

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:High
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-023 — Information Disclosure - Debug Error Messages

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/instructions.php, http://10.77.0.10/instructions.php?doc=readme |
| Severity / CVSS | **LOW** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-1295 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 2.1 (rank 31) |

**OBSERVED (tool evidence):** The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages. Evidence: PHP warning
Reported by: zap (LIVE) [EV-0005] rule zap:10023, zap (LIVE) [EV-0018] rule zap:10023

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-026 — Cross-Domain JavaScript Source File Inclusion

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/vulnerabilities/captcha/<br>Parameter: https://www.google.com/recaptcha/api.js |
| Severity / CVSS | **LOW** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-829 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 2.1 (rank 32) |

**OBSERVED (tool evidence):** The page includes one or more script files from a third-party domain. Evidence: <script src='https://www.google.com/recaptcha/api.js'></script>
Reported by: zap (LIVE) [EV-0005] rule zap:10017, zap (LIVE) [EV-0018] rule zap:10017

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-032 — Private IP Disclosure

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/phpinfo.php |
| Severity / CVSS | **LOW** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-497 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 2.1 (rank 33) |

**OBSERVED (tool evidence):** A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems. Evidence: 10.77.0.3
Reported by: zap (LIVE) [EV-0005] rule zap:2, zap (LIVE) [EV-0018] rule zap:2

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Medium
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-035 — Timestamp Disclosure - Unix

| | |
|---|---|
| Affected asset | 10.77.0.10:80<br>URLs: http://10.77.0.10/phpinfo.php, http://10.77.0.10/vulnerabilities/javascript/ |
| Severity / CVSS | **LOW** (reported by zap) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / CWE-497 / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 55/100 (medium) |
| Priority | 2.1 (rank 34) |

**OBSERVED (tool evidence):** A timestamp was disclosed by the application/web server. - Unix Evidence: 1793978282
Reported by: zap (LIVE) [EV-0005] rule zap:10096, zap (LIVE) [EV-0018] rule zap:10096

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only) | +15 request/response or matched-string evidence recorded by the tool | zap-confidence:Low
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (zap)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-046 — Suggested security header missing: referrer-policy.

| | |
|---|---|
| Affected asset | 10.77.0.11:3000<br>URLs: http://10.77.0.11:3000/ |
| Severity / CVSS | **LOW** (reported by derived from nikto message) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / n/a / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 40/100 (medium) |
| Priority | 2.1 (rank 35) |

**OBSERVED (tool evidence):** Nikto test 013587 (GET /): Suggested security header missing: referrer-policy.
Reported by: nikto (LIVE) [EV-0006] rule nikto:013587

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

## F-049 — Suggested security header missing: permissions-policy.

| | |
|---|---|
| Affected asset | 10.77.0.11:3000<br>URLs: http://10.77.0.11:3000/ |
| Severity / CVSS | **LOW** (reported by derived from nikto message) · CVSS: not provided by any tool |
| CVE / CWE / OWASP | none reported / n/a / n/a |
| MITRE ATT&CK (indicative) | n/a |
| Validation status | **OBSERVED** · confidence 40/100 (medium) |
| Priority | 2.1 (rank 36) |

**OBSERVED (tool evidence):** Nikto test 013587 (GET /): Suggested security header missing: permissions-policy.
Reported by: nikto (LIVE) [EV-0006] rule nikto:013587

**ANALYSIS (rule-based inference):** Confidence reasons: +40 reported by a tool test or rule (not version-only)
Risk factors: base 2.5 (no CVSS available; midpoint of 'low' severity (derived from nikto message)); exploitability x1.0 (no known-exploited evidence in the offline snapshot); confidence weight x0.85

# 5. Impact and Remediation

| ID | Technical / business impact | Recommended remediation | References |
|---|---|---|---|
| F-058 | Attacker script can run in a victim's browser: session theft, defacement, phishing. | Encode output according to context and validate input. | CWE-79 |
| F-040 | Data theft or modification, potential full database compromise. | Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application. | https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html |
| F-041 | Data theft or modification, potential full database compromise. | Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application. | https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html |
| F-004 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Define a restrictive Content-Security-Policy appropriate for the application. | https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html; https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP |

| ID | Technical / business impact | Recommended remediation | References |
|---|---|---|---|
| F-007 | Reveals file structure and potentially sensitive files to anyone. | Disable automatic directory indexing (e.g. 'Options -Indexes' in Apache). | CWE-548; https://cwe.mitre.org/data/definitions/548.html |
| F-047 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Define a restrictive Content-Security-Policy appropriate for the application. | https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html; https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP |
| F-039 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons. | https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html |
| F-017 | Users can be tricked into clicking hidden UI; may enable unwanted actions in an authenticated session. | Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive. | https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options |
| F-020 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user. | CWE-550 |

| ID | Technical / business impact | Recommended remediation | References |
|---|---|---|---|
| F-024 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons. | https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html |
| F-025 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons. | https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html |

| ID | Technical / business impact | Recommended remediation | References |
|---|---|---|---|
| F-027 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons. | https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html |
| F-028 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Provide a valid integrity attribute to the tag. | https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity |

| ID | Technical / business impact | Recommended remediation | References |
|---|---|---|---|
| F-029 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons. | https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html |
| F-030 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons. | https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html |

| ID | Technical / business impact | Recommended remediation | References |
|---|---|---|---|
| F-034 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons. | https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html; https://cwe.mitre.org/data/definitions/352.html |
| F-036 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header. | https://caniuse.com/#search=content+security+policy; https://content-security-policy.com/ |
| F-037 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header. | https://caniuse.com/#search=content+security+policy; https://content-security-policy.com/ |
| F-038 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header. | https://caniuse.com/#search=content+security+policy; https://content-security-policy.com/ |
| F-055 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner. | https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy |
| F-016 | Script (e.g. via XSS) can read the session cookie, enabling account takeover. | Ensure that the HttpOnly flag is set for all cookies. | https://owasp.org/www-community/HttpOnly |
| F-057 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Make sure that every sensitive form transmits content over HTTPS. | CWE-523 |

| ID | Technical / business impact | Recommended remediation | References |
|---|---|---|---|
| F-001 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Upgrade to a currently supported release and apply vendor security updates. | CWE-1104 |
| F-005 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Send 'X-Content-Type-Options: nosniff' on all responses. | https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options; https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) |
| F-014 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details. | https://httpd.apache.org/docs/current/mod/core.html#servertokens; https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) |
| F-018 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies. | https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site |
| F-059 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Disable TCP timestamps on the host or filter them at the network boundary. | - |
| F-002 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | See tool guidance; no automated recommendation available. | https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy |
| F-003 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | See tool guidance; no automated recommendation available. | https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy |
| F-013 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives. | https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/ |
| F-023 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Disable debugging messages before pushing to production. | CWE-1295 |
| F-026 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application. | CWE-829 |
| F-032 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers. | https://datatracker.ietf.org/doc/html/rfc1918 |

| ID | Technical / business impact | Recommended remediation | References |
|---|---|---|---|
| F-035 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns. | https://cwe.mitre.org/data/definitions/200.html |
| F-046 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | See tool guidance; no automated recommendation available. | https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy |
| F-049 | Increases attack surface or weakens a defensive control; impact depends on how the affected system is used (asset owner to assess). | See tool guidance; no automated recommendation available. | https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy |

# 6. Assessment Limitations, Assumptions and Human Approvals

• nessus data in this report is IMPORTED from 'SAMPLE-sample_nessus_dvwa.nessus' and was not executed by ARGUS.
• burp data in this report is IMPORTED from 'SAMPLE-sample_burp_dvwa.xml' and was not executed by ARGUS.
• openvas data in this report is IMPORTED from 'SAMPLE-sample_openvas_dvwa.xml' and was not executed by ARGUS.
• 3 finding(s) in oos.nessus were dropped: their hosts are outside the authorized scope (8.8.8.8).
• nessus data in this report is IMPORTED from 'oos.nessus' and was not executed by ARGUS.
• Findings are limited to what the integrated tools could observe; absence of a finding is not proof of absence.
• Exposure is assumed to be 'reachable over the network without authentication' for all lab assets; asset criticality defaulted to 1.0 unless set by the analyst.
• The CISA KEV check uses a small partial offline snapshot; CVE-to-version mapping uses a small reference table.
• Some data was imported from files (marked IMPORT). Imported data was not re-executed by ARGUS; sample import files are synthetic test inputs if so named.
• Grounding check of the narrative text (cited evidence ids exist; no CVE or CVSS value that no tool reported): **PASSED**.

## Human approvals (active validation)

| ID | Action | Status | Decided by | Decided at | Comment / outcome |
|---|---|---|---|---|---|
| AP-001 | zap_active:http://10.77.0.10 | EXECUTED | e2e-tester | 2026-11-06T15:23:23 | lab only, e2e test / executed: 394 raw finding(s); ZAP discovered 113 URLs; active scan was capped at 4 minute |
| AP-002 | msf_check:F-001:options | REJECTED | e2e-tester | 2026-11-06T15:24:01 | reject test / rejected by analyst; not executed |
| AP-003 | msf_check:F-001:http_version | EXECUTED | e2e-tester | 2026-11-06T15:24:10 | read-only banner check / executed: 0 raw finding(s); [+] 10.77.0.10:80 Apache/2.4.25 (Debian) ( 302-login.php |

Assessment timestamps: first audit event 2026-11-06T15:19:56+00:00, last 2026-11-06T15:27:44+00:00 (UTC).

# Appendix A. Evidence index (traceability)

Every finding ID above links to evidence IDs here. Each file's SHA-256 was computed when it was captured; the raw file is available in the ARGUS data folder.

| Evidence | Tool | Mode | Captured (UTC) | File | SHA-256 | Locator |
|---|---|---|---|---|---|---|
| EV-0001 | nmap | LIVE | 2026-11-06T15:20:14 | artifacts/A-9a4f8d52/J-001_nmap.xml | d769d0f3e48f9374... | nmaprun |
| EV-0002 | nmap | LIVE | 2026-11-06T15:20:22 | artifacts/A-9a4f8d52/J-002_nmap.xml | 263284a6fbe71bb0... | nmaprun |
| EV-0003 | nmap | LIVE | 2026-11-06T15:20:35 | artifacts/A-9a4f8d52/J-003_nmap.xml | fb324d22b2bfaafc... | nmaprun |
| EV-0004 | nikto | LIVE | 2026-11-06T15:20:40 | rtifacts/A-9a4f8d52/J-004_nikto.json | 7b824a917e8bf226... | $.vulnerabilities |
| EV-0005 | zap | LIVE | 2026-11-06T15:20:47 | artifacts/A-9a4f8d52/J-007_zap.json | bf28cf0f804ffcf4... | $.alerts |
| EV-0006 | nikto | LIVE | 2026-11-06T15:22:28 | rtifacts/A-9a4f8d52/J-008_nikto.json | f4890a1550ff0a47... | $.vulnerabilities |
| EV-0007 | zap | LIVE | 2026-11-06T15:22:59 | artifacts/A-9a4f8d52/J-011_zap.json | 3c275d89f35834f9... | $.alerts |
| EV-0008 | argus-http-check | LIVE | 2026-11-06T15:23:07 | ifacts/A-9a4f8d52/J-012_validate.txt | 8f158639c99f0d24... | response headers |
| EV-0009 | argus-http-check | LIVE | 2026-11-06T15:23:07 | ifacts/A-9a4f8d52/J-013_validate.txt | 29f93b9d0f043548... | response headers |
| EV-0010 | argus-http-check | LIVE | 2026-11-06T15:23:08 | ifacts/A-9a4f8d52/J-014_validate.txt | 4434317c01596720... | response headers |
| EV-0011 | argus-http-check | LIVE | 2026-11-06T15:23:09 | ifacts/A-9a4f8d52/J-015_validate.txt | c53127cb34b5ddd0... | response headers |
| EV-0012 | argus-http-check | LIVE | 2026-11-06T15:23:09 | ifacts/A-9a4f8d52/J-016_validate.txt | 8316cb125aebdbfa... | response headers |
| EV-0013 | argus-http-check | LIVE | 2026-11-06T15:23:10 | ifacts/A-9a4f8d52/J-017_validate.txt | 2e0cff227c3504c7... | response headers |
| EV-0014 | argus-http-check | LIVE | 2026-11-06T15:23:10 | ifacts/A-9a4f8d52/J-018_validate.txt | 011bc2fb57986d78... | response headers |
| EV-0015 | argus-http-check | LIVE | 2026-11-06T15:23:11 | ifacts/A-9a4f8d52/J-019_validate.txt | 35bfccf9ab7829de... | response headers |
| EV-0016 | argus-http-check | LIVE | 2026-11-06T15:23:12 | ifacts/A-9a4f8d52/J-020_validate.txt | d8b490c8d714bde4... | response headers |
| EV-0017 | argus-http-check | LIVE | 2026-11-06T15:23:12 | ifacts/A-9a4f8d52/J-021_validate.txt | 391703861a24f9b6... | response headers |
| EV-0018 | zap | LIVE | 2026-11-06T15:23:46 | artifacts/A-9a4f8d52/J-022_zap.json | d4b43f5cbea32a1e... | $.alerts |
| EV-0019 | metasploit | LIVE | 2026-11-06T15:26:05 | artifacts/A-9a4f8d52/J-023_msf.txt | b62d2ac32a4c9984... | stdout |
| EV-0020 | nessus | IMPORT | 2026-11-06T15:26:10 | sus_SAMPLE-sample_nessus_dvwa.nessus | 7886ec8c9c3bbcd6... | file |
| EV-0021 | burp | IMPORT | 2026-11-06T15:26:14 | d52/burp_SAMPLE-sample_burp_dvwa.xml | afd369a88257e3c1... | file |
| EV-0022 | openvas | IMPORT | 2026-11-06T15:26:17 | envas_SAMPLE-sample_openvas_dvwa.xml | 1ddf666d5d954283... | file |

| Evidence | Tool | Mode | Captured (UTC) | File | SHA-256 | Locator |
|---|---|---|---|---|---|---|
| EV-0023 | nessus | IMPORT | 2026-11-06T15:26:23 | tifacts/A-9a4f8d52/nessus_oos.nessus | d8af3a9f8ece157a... | file |
| EV-0024 | nessus | IMPORT | 2026-11-06T15:26:28 | tifacts/A-9a4f8d52/nessus_bad.nessus | 22f81c28a81ea234... | file |
| EV-0025 | argus-http-check | LIVE | 2026-11-06T15:26:36 | rtifacts/A-9a4f8d52/J-024_retest.txt | 15061f710cb4633b... | response headers |

# Appendix B. Refuted alerts (false positives)

| ID | Alert | Asset | Why refuted | Evidence |
|---|---|---|---|---|
| F-006 | Suggested security header missing: strict-transport-security | 10.77.0.10:80 | The service is plain HTTP. Browsers ignore Strict-Transport-Security on HTTP, so this check does not apply until HTTPS is enabled. | EV-0004, EV-0008 |
| F-048 | Suggested security header missing: strict-transport-security | 10.77.0.11:3000 | The service is plain HTTP. Browsers ignore Strict-Transport-Security on HTTP, so this check does not apply until HTTPS is enabled. | EV-0006, EV-0016 |

# Appendix C. Agent decision log

**D-001** [scope] planner: rules · chose: nmap_scan:10.77.0.0/24
Reasoning: No hosts or services are known yet. Service discovery is the prerequisite for choosing every other tool.
Scope check: 10.77.0.0/24: in scope
Outcome: pending

**D-002** [recon] planner: rules · chose: nmap_scan:10.77.0.0/24
Reasoning: No hosts or services are known yet. Service discovery is the prerequisite for choosing every other tool.
Scope check: nmap/standard on 10.77.0.0/24 allowed
Outcome: completed: 0 raw finding(s), total findings 0 -> 0

**D-003** [enumeration] planner: rules · chose: nmap_enum:10.77.0.10
Reasoning: HTTP found on 10.77.0.10 port(s) [80]: NSE http scripts reveal titles, methods and common paths cheaply before heavier scans.
Scope check: nmap/standard on 10.77.0.10 allowed
Outcome: completed: 0 raw finding(s), total findings 0 -> 0

**D-004** [enumeration] planner: rules · chose: nmap_enum:10.77.0.11
Reasoning: HTTP found on 10.77.0.11 port(s) [3000]: NSE http scripts reveal titles, methods and common paths cheaply before heavier scans.
Scope check: nmap/standard on 10.77.0.11 allowed
Outcome: completed: 0 raw finding(s), total findings 0 -> 0

**D-005** [vulnerability-analysis] planner: rules · chose: nikto:http://10.77.0.10
Reasoning: http://10.77.0.10 serves HTTP: Nikto checks server configuration and known files; complements ZAP, and a second tool lets findings be cross-checked.
Scope check: nikto/standard on 10.77.0.10 allowed
Outcome: completed: 14 raw finding(s), total findings 0 -> 12

**D-006** [vulnerability-analysis] planner: rules · chose: zap_passive:http://10.77.0.10
Reasoning: http://10.77.0.10 is a web application: ZAP spider + passive analysis maps the app and flags headers, cookies and forms without sending attack payloads.
Scope check: zap/standard on 10.77.0.10 allowed
Outcome: completed: 394 raw finding(s), total findings 12 -> 41

**D-007** [vulnerability-analysis] planner: rules · chose: nikto:http://10.77.0.11:3000
Reasoning: http://10.77.0.11:3000 serves HTTP: Nikto checks server configuration and known files; complements ZAP, and a second tool lets findings be cross-checked.
Scope check: nikto/standard on 10.77.0.11 allowed
Outcome: completed: 28 raw finding(s), total findings 41 -> 54

**D-008** [vulnerability-analysis] planner: rules · chose: zap_passive:http://10.77.0.11:3000
Reasoning: http://10.77.0.11:3000 is a web application: ZAP spider + passive analysis maps the app and flags headers, cookies and forms without sending attack payloads.
Scope check: zap/standard on 10.77.0.11 allowed
Outcome: completed: 238 raw finding(s), total findings 54 -> 56

**D-009** [triage] planner: rules · chose: validate:F-006, validate:F-004, validate:F-014, validate:F-005, validate:F-016, validate:F-017, validate:F-018, validate:F-007, validate:F-048, validate:F-047
Reasoning: 10 configuration findings can each be confirmed or refuted with one harmless GET. Doing this before ranking removes false positives so they do not distort priorities.
Scope check: nmap/standard on 10.77.0.10 allowed
Outcome: validation verdicts: F-006: refuted; F-004: confirmed; F-014: confirmed; F-005: confirmed; F-016: confirmed; F-017: confirmed; F-018: confirmed; F-007: confirmed; F-048: refuted; F-047: confirmed

**D-010** [import] planner: analyst · chose: import:SAMPLE-sample_nessus_dvwa.nessus
Reasoning: Imported 3 in-scope finding(s): 1 new, 2 merged with existing findings; 0 out-of-scope dropped.
Scope check:
Outcome: IMPORT only: no scan was executed for this tool.

**D-011** [import] planner: analyst · chose: import:SAMPLE-sample_burp_dvwa.xml
Reasoning: Imported 2 in-scope finding(s): 1 new, 1 merged with existing findings; 0 out-of-scope dropped.
Scope check:
Outcome: IMPORT only: no scan was executed for this tool.

**D-012** [import] planner: analyst · chose: import:SAMPLE-sample_openvas_dvwa.xml
Reasoning: Imported 1 in-scope finding(s): 1 new, 0 merged with existing findings; 0 out-of-scope dropped.
Scope check:
Outcome: IMPORT only: no scan was executed for this tool.

**D-013** [import] planner: analyst · chose: import:oos.nessus
Reasoning: Imported 0 in-scope finding(s): 0 new, 0 merged with existing findings; 3 out-of-scope dropped.
Scope check:
Outcome: IMPORT only: no scan was executed for this tool.

# Appendix E. Informational observations

Items reported by tools at informational level. They are context, not vulnerabilities, and are not ranked.

| ID | Observation | Asset | Source | Evidence |
|---|---|---|---|---|
| F-008 | Configuration information may be available remotely. | 10.77.0.10:80 | nikto | EV-0004 |
| F-009 | Apache default file found. | 10.77.0.10:80 | nikto | EV-0004 |
| F-010 | Admin login page/section found. | 10.77.0.10:80 | nikto | EV-0004 |
| F-011 | .gitignore file found. It is possible to grasp the directory structure. | 10.77.0.10:80 | nikto | EV-0004 |
| F-012 | X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTT | 10.77.0.10:80 | nikto | EV-0004 |
| F-015 | Session Management Response Identified | 10.77.0.10:80 | zap | EV-0005, EV-0018 |
| F-019 | Authentication Request Identified | 10.77.0.10:80 | zap | EV-0005, EV-0018 |
| F-021 | User Controllable HTML Element Attribute (Potential XSS) | 10.77.0.10:80 | zap | EV-0005, EV-0018 |
| F-022 | Information Disclosure - Suspicious Comments | 10.77.0.10:80 | zap | EV-0005, EV-0018 |
| F-031 | Information Disclosure - Sensitive Information in URL | 10.77.0.10:80 | zap | EV-0005, EV-0018 |
| F-033 | Modern Web Application | 10.77.0.10:80 | zap | EV-0005, EV-0018 |
| F-042 | Retrieved access-control-allow-origin header: *. | 10.77.0.11:3000 | nikto | EV-0006 |
| F-043 | Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs. | 10.77.0.11:3000 | nikto | EV-0006 |
| F-044 | /robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200). | 10.77.0.11:3000 | nikto | EV-0006 |
| F-045 | contains 1 entry which should be manually viewed. | 10.77.0.11:3000 | nikto | EV-0006 |
| F-050 | This might be interesting. | 10.77.0.11:3000 | nikto | EV-0006 |
| F-051 | Contains authorization information. | 10.77.0.11:3000 | nikto | EV-0006 |
| F-052 | A user's home directory may be set to the web root, the shell history was retrieved. This | 10.77.0.11:3000 | nikto | EV-0006 |
| F-053 | Database SQL?. | 10.77.0.11:3000 | nikto | EV-0006 |
| F-054 | JAMon - Java Application Monitor Admin interface identified. Versions 2.7 and earlier cont | 10.77.0.11:3000 | nikto | EV-0006 |
| F-056 | Modern Web Application | 10.77.0.11:3000 | zap | EV-0007 |

# Appendix D. Audit trail (hash-chained)

Chain verification: INTACT.

| # | Time (UTC) | Actor | Action | Hash |
|---|---|---|---|---|
| 359 | 2026-11-06T15:19:56 | analyst | assessment.create | 897f265203c3ea |
| 360 | 2026-11-06T15:19:56 | scope-guard | scope.check | da2dff6332481c |
| 361 | 2026-11-06T15:19:57 | agent | plan.proposed | 9a002be17b71f3 |
| 362 | 2026-11-06T15:19:59 | e2e-tester | plan.approved | 8a1f9b7a3fd41f |
| 363 | 2026-11-06T15:19:59 | agent | decision | a5eb07aaf49625 |
| 364 | 2026-11-06T15:19:59 | agent | action.start | 55fa1c201038ce |
| 365 | 2026-11-06T15:20:14 | agent | action.done | 4f0d4d43ccc7ec |
| 366 | 2026-11-06T15:20:14 | agent | decision | 3ad05ec93a1308 |
| 367 | 2026-11-06T15:20:14 | agent | action.start | 2d86ddebe3696e |
| 368 | 2026-11-06T15:20:22 | agent | action.done | 9bfa00ac12979c |
| 369 | 2026-11-06T15:20:23 | agent | decision | a6091bd29d725a |
| 370 | 2026-11-06T15:20:23 | agent | action.start | 2a9b26b341a88e |
| 371 | 2026-11-06T15:20:35 | agent | action.done | 98d03c4908a4a3 |
| 372 | 2026-11-06T15:20:35 | agent | decision | e96840ec048f3a |
| 373 | 2026-11-06T15:20:35 | agent | action.start | 20d4237cda7df6 |
| 374 | 2026-11-06T15:20:40 | agent | action.done | d2868449d9c1d4 |
| 375 | 2026-11-06T15:20:40 | agent | decision | 11bda21913add0 |
| 376 | 2026-11-06T15:20:40 | agent | action.start | 2d96c1bc475109 |
| 377 | 2026-11-06T15:20:47 | agent | action.done | 90a67ead276030 |
| 378 | 2026-11-06T15:20:47 | agent | decision | 567cb55515e137 |
| 379 | 2026-11-06T15:20:47 | agent | action.start | b03b0342651bb8 |
| 380 | 2026-11-06T15:22:28 | agent | action.done | d6cfe7b440f543 |
| 381 | 2026-11-06T15:22:30 | agent | decision | 343e01fb0e7624 |
| 382 | 2026-11-06T15:22:30 | agent | action.start | 5d887cb7b4aca6 |
| 383 | 2026-11-06T15:22:59 | agent | action.done | 25cbcfd773b9db |
| 384 | 2026-11-06T15:23:05 | agent | decision | cb9ff8ffeeb7c0 |
| 385 | 2026-11-06T15:23:05 | agent | action.start | fc88c8fa441611 |
| 386 | 2026-11-06T15:23:07 | agent | action.done | e90b8961f7039c |
| 387 | 2026-11-06T15:23:07 | agent | action.start | 9edbc7e7506175 |
| 388 | 2026-11-06T15:23:07 | agent | action.done | 6903cb9ed84ab2 |
| 389 | 2026-11-06T15:23:07 | agent | action.start | 2b1dd03d705221 |
| 390 | 2026-11-06T15:23:08 | agent | action.done | 433ecadd73dd76 |
| 391 | 2026-11-06T15:23:08 | agent | action.start | c6c876eb060c44 |
| 392 | 2026-11-06T15:23:09 | agent | action.done | 47910fde272acc |
| 393 | 2026-11-06T15:23:09 | agent | action.start | c9c5eb1524d593 |
| 394 | 2026-11-06T15:23:09 | agent | action.done | 9aaea3f58b19b5 |
| 395 | 2026-11-06T15:23:09 | agent | action.start | ae22ca81a0fe0a |
| 396 | 2026-11-06T15:23:10 | agent | action.done | c1b16cacc9b092 |

| # | Time (UTC) | Actor | Action | Hash |
|---|---|---|---|---|
| 397 | 2026-11-06T15:23:10 | agent | action.start | 212538da753ee0 |
| 398 | 2026-11-06T15:23:10 | agent | action.done | b6e0896d976f96 |
| 399 | 2026-11-06T15:23:11 | agent | action.start | bb58bd638c1908 |
| 400 | 2026-11-06T15:23:11 | agent | action.done | 285404f10cc82d |
| 401 | 2026-11-06T15:23:11 | agent | action.start | 9aa28dfcfd515d |
| 402 | 2026-11-06T15:23:12 | agent | action.done | 65672501773e30 |
| 403 | 2026-11-06T15:23:12 | agent | action.start | a5e0adc04455f6 |
| 404 | 2026-11-06T15:23:12 | agent | action.done | be6301d91c3f60 |
| 405 | 2026-11-06T15:23:16 | agent | approval.requested | 2637eb062a645d |
| 406 | 2026-11-06T15:23:16 | agent | assessment.ready-for-review | 636873dfd144fb |
| 407 | 2026-11-06T15:23:23 | e2e-tester | approval.approved | 63646b07a9e5f0 |
| 408 | 2026-11-06T15:23:23 | e2e-tester(approved) | action.start | b39a0d391437c3 |
| 409 | 2026-11-06T15:23:46 | e2e-tester(approved) | action.done | 50b10ea4326539 |
| 410 | 2026-11-06T15:23:46 | agent | approval.outcome | 5bd9645377ed1b |
| 411 | 2026-11-06T15:23:49 | agent | assessment.ready-for-review | 4a8e658221bdd2 |
| 412 | 2026-11-06T15:23:59 | analyst | approval.requested | cd7a7b28fa2c1b |
| 413 | 2026-11-06T15:24:01 | e2e-tester | approval.rejected | 459d3686ea227d |
| 414 | 2026-11-06T15:24:04 | agent | assessment.ready-for-review | 6488cfeb93dd1e |
| 415 | 2026-11-06T15:24:08 | analyst | approval.requested | 4aa8c9bedef41a |
| 416 | 2026-11-06T15:24:10 | e2e-tester | approval.approved | 0ca0eb6154160f |
| 417 | 2026-11-06T15:24:10 | e2e-tester(approved) | action.start | 07f9840a220553 |
| 418 | 2026-11-06T15:26:05 | e2e-tester(approved) | action.done | 59235bbc6b8eb9 |
| 419 | 2026-11-06T15:26:05 | agent | approval.outcome | 2df1cb32c35cfd |
| 420 | 2026-11-06T15:26:08 | agent | assessment.ready-for-review | 499b46444cb4bc |
| 421 | 2026-11-06T15:26:10 | analyst | import | 9267a3e226fd42 |
| 422 | 2026-11-06T15:26:11 | agent | assessment.ready-for-review | 655c4ac2e4cd95 |
| 423 | 2026-11-06T15:26:14 | analyst | import | 2331e1a16364b6 |
| 424 | 2026-11-06T15:26:15 | agent | assessment.ready-for-review | 421127d8e711d1 |
| 425 | 2026-11-06T15:26:17 | analyst | import | e6ed8bd411ab29 |
| 426 | 2026-11-06T15:26:19 | agent | assessment.ready-for-review | e69fe4c6c65ab3 |
| 427 | 2026-11-06T15:26:23 | scope-guard | import.dropped | 5baeb256ad9760 |
| 428 | 2026-11-06T15:26:23 | analyst | import | 9a14fa280dcff8 |
| 429 | 2026-11-06T15:26:24 | agent | assessment.ready-for-review | 2785fd5dbbb4f0 |
| 430 | 2026-11-06T15:26:36 | analyst | retest | 00c2ba8ccaa4c1 |
| 431 | 2026-11-06T15:27:44 | analyst | report.download | f35fd3178f29e4 |